



Blockchain Server(10.9.2.20)

Report generated by Nessus™

Thu, 18 Apr 2024 18:56:50 GMT

TABLE OF CONTENTS

Compliance 'FAILED'

Compliance 'SKIPPED'

Compliance 'PASSED'

Compliance 'INFO', 'WARNING', 'ERROR'

Vulnerabilities by Host

- 10.9.2.20.....9

Unsupported Software Report

- No Results:..... 101

Remediations

- Suggested Remediations.....103

Vulnerabilities by Host

- 10.9.2.20..... 105

Overview

- Vulnerability Instances: all and exploitable, by severity..... 110

Top 10 Critical Vulnerabilities

- No Results:..... 112
- No Results:..... 113

Top 10 High Vulnerabilities

- No Results:..... 115
- Top 10 High Vulnerabilities: (CVSS v2.0)..... 116

Top 10 Most Prevalent Vulnerabilities

- Top 10 Most Prevalent Vulnerabilities: (VPR)..... 118

• Top 10 Most Prevalent Vulnerabilities: (CVSS v2.0).....	119
---	-----

Compliance 'FAILED'

Compliance 'SKIPPED'

Compliance 'PASSED'

Compliance 'INFO', 'WARNING', 'ERROR'

Vulnerabilities by Host

10.9.2.20



Scan Information

Start time: Thu Apr 18 18:17:47 2024
End time: Thu Apr 18 18:56:49 2024

Host Information

IP: 10.9.2.20
MAC Address: 00:50:56:AC:63:49
OS: Linux Kernel 5.15.0-205.149.5.1.el8uek.x86_64 on Oracle Linux Server release 8.9

Vulnerabilities

144564 - Oracle Linux 8 : ELSA-2020-5620-1: / postgresql:12 (ELSA-2020-56201)

Description

The remote Oracle Linux 8 host has packages installed that are affected by multiple vulnerabilities as referenced in the ELSA-2020-56201 advisory.

- It was found that PostgreSQL versions before 12.4, before 11.9 and before 10.14 did not properly sanitize the search_path during logical replication. An authenticated attacker could use this flaw in an attack similar to CVE-2018-1058, in order to execute arbitrary SQL command in the context of the user used for replication. (CVE-2020-14349)

- A flaw was found in PostgreSQL's ALTER ... DEPENDS ON EXTENSION, where sub-commands did not perform authorization checks. An authenticated attacker could use this flaw in certain configurations to perform drop objects such as function, triggers, et al., leading to database corruption. This issue affects PostgreSQL versions before 12.2, before 11.7, before 10.12 and before 9.6.17. (CVE-2020-1720)

- It was found that some PostgreSQL extensions did not use search_path safely in their installation script. An attacker with sufficient privileges could use this flaw to trick an administrator into executing a specially crafted script, during the installation or update of such extension. This affects PostgreSQL versions before 12.4, before 11.9, before 10.14, before 9.6.19, and before 9.5.23. (CVE-2020-14350)

- A flaw was found in PostgreSQL versions before 13.1, before 12.5, before 11.10, before 10.15, before 9.6.20 and before 9.5.24. If a client application that creates additional database connections only reuses the basic connection parameters while dropping security-relevant parameters, an opportunity for a man-in-the-middle attack, or the ability to observe clear-text transmissions, could exist. The highest threat from this vulnerability is to data confidentiality and integrity as well as system availability. (CVE-2020-25694)

- A flaw was found in PostgreSQL versions before 13.1, before 12.5, before 11.10, before 10.15, before 9.6.20 and before 9.5.24. An attacker having permission to create non-temporary objects in at least one schema can execute arbitrary SQL functions under the identity of a superuser. The highest threat from this vulnerability is to data confidentiality and integrity as well as system availability. (CVE-2020-25695)

- A flaw was found in the psql interactive terminal of PostgreSQL in versions before 13.1, before 12.5, before 11.10, before 10.15, before 9.6.20 and before 9.5.24. If an interactive psql session uses \gset when querying a compromised server, the attacker can execute arbitrary code as the operating system account running psql. The highest threat from this vulnerability is to data confidentiality and integrity as well as system availability. (CVE-2020-25696)

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Solution

Update the affected packages.

VPR Score

5.9

STIG Severity

I

References

CVE	CVE-2020-1720
CVE	CVE-2020-14349
CVE	CVE-2020-14350
CVE	CVE-2020-25694
CVE	CVE-2020-25695
CVE	CVE-2020-25696
XREF	IAVB:2020-B-0069-S

Description

The remote Oracle Linux 8 host has packages installed that are affected by multiple vulnerabilities as referenced in the ELSA-2023-13025 advisory.

- The function `PEM_read_bio_ex()` reads a PEM file from a BIO and parses and decodes the name (e.g. CERTIFICATE), any header data and the payload data. If the function succeeds then the `name_out`, header and data arguments are populated with pointers to buffers containing the relevant decoded data.

The caller is responsible for freeing those buffers. It is possible to construct a PEM file that results in 0 bytes of payload data. In this case `PEM_read_bio_ex()` will return a failure code but will populate the header argument with a pointer to a buffer that has already been freed. If the caller also frees this buffer then a double free will occur. This will most likely lead to a crash. This could be exploited by an attacker who has the ability to supply malicious PEM files for parsing to achieve a denial of service attack. The functions `PEM_read_bio()` and `PEM_read()` are simple wrappers around `PEM_read_bio_ex()` and therefore these functions are also directly affected. These functions are also called indirectly by a number of other OpenSSL functions including `PEM_X509_INFO_read_bio_ex()` and `SSL_CTX_use_serverinfo_file()` which are also vulnerable. Some OpenSSL internal uses of these functions are not vulnerable because the caller does not free the header argument if `PEM_read_bio_ex()` returns a failure code. These locations include the `PEM_read_bio_TYPE()` functions as well as the decoders introduced in OpenSSL 3.0. The OpenSSL `asn1parse` command line application is also impacted by this issue. (CVE-2022-4450)

- There is a type confusion vulnerability relating to X.400 address processing inside an X.509 GeneralName.

X.400 addresses were parsed as an `ASN1_STRING` but the public structure definition for `GENERAL_NAME` incorrectly specified the type of the `x400Address` field as `ASN1_TYPE`. This field is subsequently interpreted by the OpenSSL function `GENERAL_NAME_cmp` as an `ASN1_TYPE` rather than an `ASN1_STRING`. When CRL checking is enabled (i.e. the application sets the `X509_V_FLAG_CRL_CHECK` flag), this vulnerability may allow an attacker to pass arbitrary pointers to a `memcmp` call, enabling them to read memory contents or enact a denial of service. In most cases, the attack requires the attacker to provide both the certificate chain and CRL, neither of which need to have a valid signature. If the attacker only controls one of these inputs, the other input must already contain an X.400 address as a CRL distribution point, which is uncommon. As such, this vulnerability is most likely to only affect applications which have implemented their own functionality for retrieving CRLs over a network. (CVE-2023-0286)

- A timing based side channel exists in the OpenSSL RSA Decryption implementation which could be sufficient to recover a plaintext across a network in a Bleichenbacher style attack. To achieve a successful decryption an attacker would have to be able to send a very large number of trial messages for decryption.

The vulnerability affects all RSA padding modes: PKCS#1 v1.5, RSA-OEAP and RSASVE. For example, in a TLS connection, RSA is commonly used by a client to send an encrypted pre-master secret to the server. An attacker that had observed a genuine connection between a client and a server could use this flaw to send trial messages to the server and record the time taken to process them. After a sufficiently large number of messages the attacker could recover the pre-master secret used for the original connection and thus be able to decrypt the application data sent over that connection. (CVE-2022-4304)

- The public API function `BIO_new_NDEF` is a helper function used for streaming ASN.1 data via a BIO. It is primarily used internally to OpenSSL to support the SMIME, CMS and PKCS7 streaming capabilities, but may also be called directly by end user applications. The function receives a BIO from the caller, prepends a new `BIO_f_asn1` filter BIO onto the front of it to form a BIO chain, and then returns the new head of the BIO chain to the caller. Under certain conditions, for example if a CMS recipient public key is invalid, the new filter BIO is freed and the function returns a NULL result indicating a failure. However, in this case, the BIO chain is not properly cleaned up and the BIO passed by the caller still retains internal pointers to the previously freed filter BIO. If the caller then goes on to call `BIO_pop()` on the BIO then a use-after-free will occur. This will most likely result in a crash. This scenario occurs

directly in the internal function `B64_write_ASN1()` which may cause `BIO_new_NDEF()` to be called and will subsequently call `BIO_pop()` on the BIO. This internal function is in turn called by the public API functions `PEM_write_bio_ASN1_stream`, `PEM_write_bio_CMS_stream`, `PEM_write_bio_PKCS7_stream`, `SMIME_write_ASN1`, `SMIME_write_CMS` and `SMIME_write_PKCS7`. Other public API functions that may be impacted by this include `i2d_ASN1_bio_stream`, `BIO_new_CMS`, `BIO_new_PKCS7`, `i2d_CMS_bio_stream` and `i2d_PKCS7_bio_stream`. The OpenSSL `cms` and `smime` command line applications are similarly affected. (CVE-2023-0215)

Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number.

Solution

Update the affected `edk2-aarch64` and / or `edk2-ovmf` packages.

VPR Score

6.0

References

CVE	CVE-2022-4304
CVE	CVE-2022-4450
CVE	CVE-2023-0215
CVE	CVE-2023-0286

Description

The remote Oracle Linux 8 host has packages installed that are affected by multiple vulnerabilities as referenced in the ELSA-2023-12855 advisory.

- A flaw was found in QEMU. The async nature of hot-unplug enables a race scenario where the net device backend is cleared before the virtio-net pci frontend has been unplugged. A malicious guest could use this time window to trigger an assertion and cause a denial of service. (CVE-2023-3301)

- A flaw was found in the QEMU built-in VNC server while processing ClientCutText messages. A wrong exit condition may lead to an infinite loop when inflating an attacker controlled zlib buffer in the `inflate\_buffer` function. This could allow a remote authenticated client who is able to send a clipboard to the VNC server to trigger a denial of service. (CVE-2023-3255)

- A vulnerability was found in libvirt. This security flaw occurs due to repeatedly querying an SR-IOV PCI device's capabilities that exposes a memory leak caused by a failure to free the virPCIVirtualFunction array within the parent struct's g_autoptr cleanup. (CVE-2023-2700)

- A flaw was found in the QEMU built-in VNC server. When a client connects to the VNC server, QEMU checks whether the current number of connections crosses a certain threshold and if so, cleans up the previous connection. If the previous connection happens to be in the handshake phase and fails, QEMU cleans up the connection again, resulting in a NULL pointer dereference issue. This could allow a remote unauthenticated client to cause a denial of service. (CVE-2023-3354)

- A flaw was found in libvirt. The virStoragePoolObjListSearch function does not return a locked pool as expected, resulting in a race condition and denial of service when attempting to lock the same object from another thread. This issue could allow clients connecting to the read-only socket to crash the libvirt daemon. (CVE-2023-3750)

- A vulnerability in the lsi53c895a device affects the latest version of qemu. A DMA-MMIO reentrancy problem may lead to memory corruption bugs like stack overflow or use-after-free. (CVE-2023-0330)

- A flaw was found in the QEMU virtual crypto device while handling data encryption/decryption requests in virtio_crypto_handle_sym_req. There is no check for the value of `src\_len` and `dst\_len` in virtio_crypto_sym_op_helper, potentially leading to a heap buffer overflow when the two values differ. (CVE-2023-3180)

Note that Nessus has not tested for these issues but has instead relied only on the application's self-reported version number.

Solution

Update the affected packages.

VPR Score

4.4

References

CVE	CVE-2023-0330
-----	---------------

CVE	CVE-2023-2700
CVE	CVE-2023-3180
CVE	CVE-2023-3255
CVE	CVE-2023-3301
CVE	CVE-2023-3354
CVE	CVE-2023-3750

70658 - SSH Server CBC Mode Ciphers Enabled

Description

The SSH server is configured to support Cipher Block Chaining (CBC) encryption. This may allow an attacker to recover the plaintext message from the ciphertext.

Note that this plugin only checks for the options of the SSH server and does not check for vulnerable software versions.

Solution

Contact the vendor or consult product documentation to disable CBC mode cipher encryption, and enable CTR or GCM cipher mode encryption.

VPR Score

3.6

References

BID	32319
CVE	CVE-2008-5161
XREF	CERT:958563
XREF	CWE:200

153953 - SSH Weak Key Exchange Algorithms Enabled

Description

The remote SSH server is configured to allow key exchange algorithms which are considered weak.

This is based on the IETF draft document Key Exchange (KEX) Method Updates and Recommendations for Secure Shell (SSH) draft-ietf-curdle-ssh-kex-sha2-20. Section 4 lists guidance on key exchange algorithms that SHOULD NOT and MUST NOT be enabled. This includes:

diffie-hellman-group-exchange-sha1

diffie-hellman-group1-sha1

gss-gex-sha1-*

gss-group1-sha1-*

gss-group14-sha1-*

rsa1024-sha1

Note that this plugin only checks for the options of the SSH server, and it does not check for vulnerable software versions.

Solution

Contact the vendor or consult product documentation to disable the weak algorithms.

141394 - Apache HTTP Server Installed (Linux)

Description

Apache HTTP Server is installed on the remote Linux host.

Solution

n/a

References

XREF IAVT:0001-T-0530

142640 - Apache HTTP Server Site Enumeration

Description

Domain names and IP addresses from Apache HTTP Server configuration file were retrieved from the remote host. Apache HTTP Server is a webserver environment written in C. Note: Only Linux- and Unix-based hosts are currently supported by this plugin.

Solution

n/a

34098 - BIOS Info (SSH)

Description

Using SMBIOS and UEFI, it was possible to get BIOS info.

Solution

N/A

39520 - Backported Security Patch Detection (SSH)

Description

Security patches may have been 'backported' to the remote SSH server without changing its version number.

Banner-based checks have been disabled to avoid false positives.

Note that this test is informational only and does not denote any security problem.

Solution

n/a

45590 - Common Platform Enumeration (CPE)

Description

By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution

n/a

182774 - Curl Installed (Linux / Unix)

Description

Curl (also known as curl and cURL) is installed on the remote Linux / Unix host.

Note that more paths will be searched and the timeout for the search will be increased if 'Perform thorough tests' setting is enabled.

Solution

n/a

55472 - Device Hostname

Description

This plugin reports a device's hostname collected via SSH or WMI.

Solution

n/a

54615 - Device Type

Description

Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution

n/a

159273 - Dockerfile Detection for Linux/UNIX

Description

The host contains Dockerfiles, text files containing instructions to build Docker images.

Solution

n/a

25203 - Enumerate IPv4 Interfaces via SSH

Description

Nessus was able to enumerate the network interfaces configured with IPv4 addresses by connecting to the remote host via SSH using the supplied credentials.

Solution

Disable any unused IPv4 interfaces.

25202 - Enumerate IPv6 Interfaces via SSH

Description

Nessus was able to enumerate the network interfaces configured with IPv6 addresses by connecting to the remote host via SSH using the supplied credentials.

Solution

Disable IPv6 if you are not actually using it. Otherwise, disable any unused IPv6 interfaces.

33276 - Enumerate MAC Addresses via SSH

Description

Nessus was able to enumerate MAC addresses by connecting to the remote host via SSH with the supplied credentials.

Solution

Disable any unused interfaces.

170170 - Enumerate the Network Interface configuration via SSH

Description

Nessus was able to parse the Network Interface data on the remote host.

Solution

n/a

179200 - Enumerate the Network Routing configuration via SSH

Description

Nessus was able to retrieve network routing information the remote host.

Solution

n/a

168980 - Enumerate the PATH Variables

Description

Enumerates the PATH variables of the current scan user.

Solution

Ensure that directories listed here are in line with corporate policy.

35716 - Ethernet Card Manufacturer Detection

Description

Each ethernet MAC address starts with a 24-bit Organizationally Unique Identifier (OUI). These OUIs are registered by IEEE.

Solution

n/a

86420 - Ethernet MAC Addresses

Description

This plugin gathers MAC addresses discovered from both remote probing of the host (e.g. SNMP and Netbios) and from running local checks (e.g. ifconfig). It then consolidates the MAC addresses into a single, unique, and uniform list.

Solution

n/a

24260 - HyperText Transfer Protocol (HTTP) Information

Description

This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive and HTTP pipelining are enabled, etc...

This test is informational only and does not denote any security problem.

Solution

n/a

10114 - ICMP Timestamp Request Remote Date Disclosure

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

References

CVE	CVE-1999-0524
XREF	CWE:200

171410 - IP Assignment Method Detection

Description

Enumerates the IP address assignment method(static/dynamic).

Solution

n/a

147817 - Java Detection and Identification (Linux / Unix)

Description

One or more instances of Java are installed on the remote Linux / Unix host. This may include private JREs bundled with the Java Development Kit (JDK).

Notes:

- This plugin attempts to detect Oracle and non-Oracle JRE instances such as Zulu Java, Amazon Corretto, AdoptOpenJDK, IBM Java, etc
- To discover instances of JRE that are not in PATH, or installed via a package manager, 'Perform thorough tests' setting must be enabled.

Solution

n/a

References

XREF	IAVT:0001-T-0690
------	------------------

151883 - Libgcrypt Installed (Linux/UNIX)

Description

Libgcrypt, a cryptography library, was found on the remote host.

Solution

n/a

Description

Report the mounted devices information on the target machine at scan time using the following commands.

`/bin/df -h /bin/lsblk /bin/mount -l`

This plugin only reports on the tools available on the system and omits any tool that did not return information when the command was ran.

Solution

n/a

95928 - Linux User List Enumeration

Description

Using the supplied credentials, Nessus was able to enumerate the local users and groups on the remote host.

Solution

None

45433 - Memory Information (via DMI)

Description

Using the SMBIOS (aka DMI) interface, it was possible to retrieve information about the remote system's memory devices, such as the total amount of installed memory.

Solution

n/a

129056 - Microsoft Visual Studio Code Installed (Linux)

Description

Microsoft Visual Studio Code, an integrated development environment software application, is installed on the remote Linux host.

Note: If thorough tests is enabled, this plugin will check for snap installs.

Solution

n/a

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Solution

n/a

64582 - Netstat Connection Information

Description

The remote host has listening ports or established connections that Nessus was able to extract from the results of the 'netstat' command.

Note: The output for this plugin can be very long, and is not shown by default. To display it, enable verbose reporting in scan settings.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

14272 - Netstat Portscanner (SSH)

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

Solution

n/a

178771 - Node.js Installed (Linux / UNIX)

Description

Node.js is installed on the remote Linux / UNIX host.

Solution

n/a

178772 - Node.js Modules Installed (Linux)

Description

Nessus was able to enumerate one or more Node.js modules installed on the remote host.

Solution

n/a

11936 - OS Identification

Description

Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Solution

n/a

97993 - OS Identification and Installed Software Enumeration over SSH v2 (Using New SSH Library)

Description

Nessus was able to login to the remote host using SSH or local commands and extract the list of installed packages.

Solution

n/a

117887 - OS Security Patch Assessment Available

Description

Nessus was able to determine OS security patch levels by logging into the remote host and running commands to determine the version of the operating system and its components. The remote host was identified as an operating system or device that Nessus supports for patch and update assessment. The necessary information was obtained to perform these checks.

Solution

n/a

References

XREF IAVB:0001-B-0516

148373 - OpenJDK Java Detection (Linux / Unix)

Description

One or more instances of OpenJDK Java are installed on the remote host. This may include private JREs bundled with the Java Development Kit (JDK).

Notes:

- Addition information provided in plugin Java Detection and Identification (Unix)
- Additional instances of Java may be discovered by enabling thorough tests

Solution

n/a

181418 - OpenSSH Detection

Description

An OpenSSH-based SSH server was detected on the remote host.

Solution

n/a

168007 - OpenSSL Installed (Linux)

Description

OpenSSL was detected on the remote Linux host.

The plugin timeout can be set to a custom value other than the plugin's default of 15 minutes via the 'timeout.168007' scanner setting in Nessus 8.15.1 or later.

Please see <https://docs.tenable.com/nessus/Content/SettingsAdvanced.htm#Custom> for more information.

Solution

n/a

66334 - Patch Report

Description

The remote host is missing one or more security patches. This plugin lists the newest version of each patch to install to make sure the remote host is up-to-date.

Note: Because the 'Show missing patches that have been superseded' setting in your scan policy depends on this plugin, it will always run and cannot be disabled.

Solution

Install the patches listed below.

130024 - PostgreSQL Client/Server Installed (Linux)

Description

One or more PostgreSQL server or client versions have been detected on the remote Linux host.

Solution

n/a

45432 - Processor Information (via DMI)

Description

Nessus was able to retrieve information about the remote system's hardware, such as its processor type, by using the SMBIOS (aka DMI) interface.

Solution

n/a

45405 - Reachable IPv6 address

Description

Although this host was scanned through a private IPv4 or local scope IPv6 address, some network interfaces are configured with global scope IPv6 addresses. Depending on the configuration of the firewalls and routers, this host may be reachable from Internet.

Solution

Disable IPv6 if you do not actually using it.

Otherwise, disable any unused IPv6 interfaces and implement IP filtering if needed.

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

25221 - Remote listeners enumeration (Linux / AIX)

Description

By logging into the remote host with the supplied credentials, Nessus was able to obtain the name of the process listening on the remote port.

Note that the method used by this plugin only works for hosts running Linux or AIX.

Solution

n/a

174788 - SQLite Local Detection (Linux)

Description

Version information for SQLite was retrieved from the remote host. SQLite is an embedded database written in C.

- To discover instances of SQLite that are not in PATH, or installed via a package manager, 'Perform thorough tests' setting must be enabled.

Solution

n/a

70657 - SSH Algorithms and Languages Supported

Description

This script detects which algorithms and languages are supported by the remote service for encrypting communications.

Solution

n/a

149334 - SSH Password Authentication Accepted

Description

The SSH server on the remote host accepts password authentication.

Solution

n/a

10881 - SSH Protocol Versions Supported

Description

This plugin determines the versions of the SSH protocol supported by the remote SSH daemon.

Solution

n/a

90707 - SSH SCP Protocol Detection

Description

The remote host supports the Secure Copy (SCP) protocol over SSH.

Solution

n/a

153588 - SSH SHA-1 HMAC Algorithms Enabled

Description

The remote SSH server is configured to enable SHA-1 HMAC algorithms.

Although NIST has formally deprecated use of SHA-1 for digital signatures, SHA-1 is still considered secure for HMAC as the security of HMAC does not rely on the underlying hash function being resistant to collisions.

Note that this plugin only checks for the options of the remote SSH server.

Solution

n/a

10267 - SSH Server Type and Version Information

Description

It is possible to obtain information about the remote SSH server by sending an empty authentication request.

Solution

n/a

References

XREF	IAVT:0001-T-0933
------	------------------

22964 - Service Detection

Description

Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Solution

n/a

22964 - Service Detection

Description

Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Solution

n/a

22869 - Software Enumeration (SSH)

Description

Nessus was able to list the software installed on the remote host by calling the appropriate command (e.g., 'rpm -qa' on RPM-based Linux distributions, dpkg, etc.).

Solution

Remove any software that is not in compliance with your organization's acceptable use and security policies.

References

XREF IAVT:0001-T-0502

35351 - System Information Enumeration (via DMI)

Description

Using the SMBIOS (aka DMI) interface, it was possible to retrieve information about the remote system's hardware, such as its product name and serial number.

Solution

n/a

110095 - Target Credential Issues by Authentication Protocol - No Issues Found

Description

Valid credentials were provided for an authentication protocol on the remote target and Nessus did not log any subsequent errors or failures for the authentication protocol.

When possible, Nessus tracks errors or failures related to otherwise valid credentials in order to highlight issues that may result in incomplete scan results or limited scan coverage. The types of issues that are tracked include errors that indicate that the account used for scanning did not have sufficient permissions for a particular check, intermittent protocol failures which are unexpected after the protocol has been negotiated successfully earlier in the scan, and intermittent authentication failures which are unexpected after a credential set has been accepted as valid earlier in the scan. This plugin reports when none of the above issues have been logged during the course of the scan for at least one authenticated protocol. See plugin output for details, including protocol, port, and account.

Please note the following :

- This plugin reports per protocol, so it is possible for issues to be encountered for one protocol and not another.

For example, authentication to the SSH service on the remote target may have consistently succeeded with no privilege errors encountered, while connections to the SMB service on the remote target may have failed intermittently.

- Resolving logged issues for all available authentication protocols may improve scan coverage, but the value of resolving each issue for a particular protocol may vary from target to target depending upon what data (if any) is gathered from the target via that protocol and what particular check failed. For example, consistently successful checks via SSH are more critical for Linux targets than for Windows targets, and likewise consistently successful checks via SMB are more critical for Windows targets than for Linux targets.

Solution

n/a

References

XREF IAVB:0001-B-0520

141118 - Target Credential Status by Authentication Protocol - Valid Credentials Provided

Description

Nessus was able to determine that valid credentials were provided for an authentication protocol available on the remote target because it was able to successfully authenticate directly to the remote target using that authentication protocol at least once. Authentication was successful because the authentication protocol service was available remotely, the service was able to be identified, the authentication protocol was able to be negotiated successfully, and a set of credentials provided in the scan policy for that authentication protocol was accepted by the remote service. See plugin output for details, including protocol, port, and account.

Please note the following :

- This plugin reports per protocol, so it is possible for valid credentials to be provided for one protocol and not another. For example, authentication may succeed via SSH but fail via SMB, while no credentials were provided for an available SNMP service.
- Providing valid credentials for all available authentication protocols may improve scan coverage, but the value of successful authentication for a given protocol may vary from target to target depending upon what data (if any) is gathered from the target via that protocol. For example, successful authentication via SSH is more valuable for Linux targets than for Windows targets, and likewise successful authentication via SMB is more valuable for Windows targets than for Linux targets.

Solution

n/a

56468 - Time of Last System Startup

Description

Using the supplied credentials, Nessus was able to determine when the host was last started.

Solution

n/a

10287 - Traceroute Information

Description

Makes a traceroute to the remote host.

Solution

n/a

Description

Using the supplied credentials, Nessus was able to list local users that are enabled and whose passwords never expire.

Solution

Allow or require users to change their passwords regularly.

110483 - Unix / Linux Running Processes Information

Description

Generated report details the running processes on the target machine at scan time.

This plugin is informative only and could be used for forensic investigation, malware detection, and to confirm that your system processes conform to your system policies.

Solution

n/a

152742 - Unix Software Discovery Commands Available

Description

Nessus was able to determine that it is possible for plugins to find and identify versions of software on the target host. Software that is not managed by the operating system is typically found and characterized using these commands. This was measured by running commands used by unmanaged software plugins and validating their output against expected results.

Solution

n/a

186361 - VMWare Tools or Open VM Tools Installed (Linux)

Description

VMWare Tools or Open VM Tools were detected on the remote Linux host.

Solution

n/a

20094 - VMware Virtual Machine Detection

Description

According to the MAC address of its network adapter, the remote host is a VMware virtual machine.

Solution

Since it is physically accessible through the network, ensure that its configuration matches your organization's security policy.

182155 - WebM Project WebP Image Library Installed (Linux)

Description

WebM Project WebP Image Library is installed on the remote Linux host.

Note: Thorough Tests is required for this plugin to run.

Solution

n/a

182848 - libcurl Installed (Linux / Unix)

Description

libcurl is installed on the remote Linux / Unix host.

Note that more paths will be searched and the timeout for the search will be increased if 'Perform thorough tests' setting is enabled.

Solution

n/a

Unsupported Software Report

The proliferation of unsupported and end-of-life (EOL) software is an issue for many organizations and increases the effort required to minimize risk. As software reaches end-of-life, vendors often stop providing updates and support for the older versions. This report provides system administrators with a summary of the software that is no longer supported and puts the organization at the most risk.

No Results:

No Unsupported Software Found

Remediations

Suggested Remediations

Taking the following actions across 1 hosts would resolve 57% of the vulnerabilities on the network.

ACTION TO TAKE	VULNS	HOSTS
Oracle Linux 8 : edk2 (ELSA-2023-13025): Update the affected edk2-aarch64 and / or edk2-ovmf packages.	11	1

Vulnerabilities by Host

10.9.2.20



Vulnerabilities

Total: 68

SEVERITY	CVSS V2.0	VPR SCORE	PLUGIN	NAME
HIGH	7.8	4.4	182741	Oracle Linux 8 : kvm_utils3 (ELSA-2023-12855)
HIGH	7.6	5.9	144564	Oracle Linux 8 : ELSA-2020-5620-1: / postgresql:12 (ELSA-2020-56201)
HIGH	7.1	6.0	186668	Oracle Linux 8 : edk2 (ELSA-2023-13025)
LOW	2.6	3.6	70658	SSH Server CBC Mode Ciphers Enabled
LOW	2.6	-	153953	SSH Weak Key Exchange Algorithms Enabled
INFO	N/A	-	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	141394	Apache HTTP Server Installed (Linux)
INFO	N/A	-	142640	Apache HTTP Server Site Enumeration
INFO	N/A	-	34098	BIOS Info (SSH)
INFO	N/A	-	39520	Backported Security Patch Detection (SSH)
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	182774	Curl Installed (Linux / Unix)
INFO	N/A	-	55472	Device Hostname
INFO	N/A	-	54615	Device Type
INFO	N/A	-	159273	Dockerfile Detection for Linux/UNIX
INFO	N/A	-	25203	Enumerate IPv4 Interfaces via SSH
INFO	N/A	-	25202	Enumerate IPv6 Interfaces via SSH
INFO	N/A	-	33276	Enumerate MAC Addresses via SSH

INFO	N/A	-	170170	Enumerate the Network Interface configuration via SSH
INFO	N/A	-	179200	Enumerate the Network Routing configuration via SSH
INFO	N/A	-	168980	Enumerate the PATH Variables
INFO	N/A	-	35716	Ethernet Card Manufacturer Detection
INFO	N/A	-	86420	Ethernet MAC Addresses
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	171410	IP Assignment Method Detection
INFO	N/A	-	147817	Java Detection and Identification (Linux / Unix)
INFO	N/A	-	151883	Libgcrypt Installed (Linux/UNIX)
INFO	N/A	-	157358	Linux Mounted Devices
INFO	N/A	-	95928	Linux User List Enumeration
INFO	N/A	-	45433	Memory Information (via DMI)
INFO	N/A	-	129056	Microsoft Visual Studio Code Installed (Linux)
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	64582	Netstat Connection Information
INFO	N/A	-	14272	Netstat Portscanner (SSH)
INFO	N/A	-	178771	Node.js Installed (Linux / UNIX)
INFO	N/A	-	178772	Node.js Modules Installed (Linux)
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	97993	OS Identification and Installed Software Enumeration over SSH v2 (Using New SSH Library)
INFO	N/A	-	117887	OS Security Patch Assessment Available
INFO	N/A	-	148373	OpenJDK Java Detection (Linux / Unix)
INFO	N/A	-	181418	OpenSSH Detection
INFO	N/A	-	168007	OpenSSL Installed (Linux)
INFO	N/A	-	66334	Patch Report

INFO	N/A	-	130024	PostgreSQL Client/Server Installed (Linux)
INFO	N/A	-	45432	Processor Information (via DMI)
INFO	N/A	-	45405	Reachable IPv6 address
INFO	N/A	-	25221	Remote listeners enumeration (Linux / AIX)
INFO	N/A	-	174788	SQLite Local Detection (Linux)
INFO	N/A	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	10881	SSH Protocol Versions Supported
INFO	N/A	-	90707	SSH SCP Protocol Detection
INFO	N/A	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	10267	SSH Server Type and Version Information
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	22869	Software Enumeration (SSH)
INFO	N/A	-	35351	System Information Enumeration (via DMI)
INFO	N/A	-	110095	Target Credential Issues by Authentication Protocol - No Issues Found
INFO	N/A	-	141118	Target Credential Status by Authentication Protocol - Valid Credentials Provided
INFO	N/A	-	56468	Time of Last System Startup
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	83303	Unix / Linux - Local Users Information : Passwords Never Expire
INFO	N/A	-	110483	Unix / Linux Running Processes Information
INFO	N/A	-	152742	Unix Software Discovery Commands Available
INFO	N/A	-	186361	VMWare Tools or Open VM Tools Installed (Linux)
INFO	N/A	-	20094	VMware Virtual Machine Detection
INFO	N/A	-	182155	WebM Project WebP Image Library Installed (Linux)

Overview

The Overview section contains two matrices that provide summary counts, by severity, using VPR or CVSS. Within each cell there is a number for the vulnerability count, and in parentheses the count of exploitable vulnerabilities. Also provided is the count based on severity level.

Vulnerability Instances: all and exploitable, by severity

VPR: all(exploitable)



CVSS v2.0: all(exploitable)



Top 10 Critical Vulnerabilities

The two tables in this chapter provide a top 10 vulnerabilities grouped using the critical VPR or critical CVSS. For VPR and CVSS v3.0 the rating is 9.0 - 10, for CVSS v2.0 the rating is 10. The vulnerabilities identified using VPR are the most active in the wild, and based on an in-depth threat analysis, are considered the most critical to mitigate. Traditionally, the method for identifying risk was most commonly with CVSS v3.0 or CVSS v2.0. While each still remain very important, and should be mitigated, these vulnerabilities are not given the same context as VPR identified vulnerabilities.

No Results:

No Top 10 Critical Vulnerabilities: (VPR) Found

No Results:

No Top 10 Critical Vulnerabilities: (CVSS v2.0) Found

Top 10 High Vulnerabilities

The two tables in this chapter provide a top ' + limit + ' vulnerabilities grouped using the High VPR or High CVSS. For VPR and CVSS v3.0 the rating is 7.0 - 8.9, for CVSS v2.0 the rating is 7.0 - 9.9. The vulnerabilities identified using VPR are the most active in the wild and based on an in-depth threat analysis are considered the most critical to mitigate. Traditionally, the method for identifying risk was most commonly with CVSS v3.0 or CVSS v2.0. While each still remain very important, and should be mitigated, these vulnerabilities are not given the same context as VPR identified vulnerabilities.

No Results:

No Top 10 High Vulnerabilities: (VPR) Found

Top 10 High Vulnerabilities: (CVSS v2.0)

Top 10 most prevalent high vulnerabilities

Plugin ID	Plugin Name	Plugin Family	CVSS v2.0	Known Exploit?	Publication Date	Count
182741	Oracle Linux 8 : kvm_utils3 (ELSA-2023-12855)	Oracle Linux Local Security Checks	7.8	-	2023/03/06	1
144564	Oracle Linux 8 : ELSA-2020-5620-1: / postgresql:12 (ELSA-2020-56201)	Oracle Linux Local Security Checks	7.6	-	2020/02/13	1
186668	Oracle Linux 8 : edk2 (ELSA-2023-13025)	Oracle Linux Local Security Checks	7.1	-	2022/12/15	1

Top 10 Most Prevalent Vulnerabilities

The two tables in this chapter provide a top 10 vulnerabilities grouped using the Medium through Critical. For VPR, CVSS v3.0, and CVSS v2.0 the rating is 4.0 - 10. The vulnerabilities identified using VPR are the most active in the wild and based on an in-depth threat analysis are considered the most critical to mitigate. Traditionally, the method for identifying risk was most commonly with CVSS v3.0 or CVSS v2.0. While each still remain very important, and should be mitigated, these vulnerabilities are not given the same context as VPR identified vulnerabilities.

Top 10 Most Prevalent Vulnerabilities: (VPR)

Top 10 most prevalent (medium, high, critical) vulnerabilities

Plugin ID	Plugin Name	Plugin Family	VPR	Known Exploit?	Publication Date	Count
186668	Oracle Linux 8 : edk2 (ELSA-2023-13025)	Oracle Linux Local Security Checks	6.0	-	2022/12/15	1
144564	Oracle Linux 8 : ELSA-2020-5620-1: / postgresql:12 (ELSA-2020-56201)	Oracle Linux Local Security Checks	5.9	-	2020/02/13	1
182741	Oracle Linux 8 : kvm_utils3 (ELSA-2023-12855)	Oracle Linux Local Security Checks	4.4	-	2023/03/06	1

Top 10 Most Prevalent Vulnerabilities: (CVSS v2.0)

Top 10 most prevalent (medium, high, critical) vulnerabilities

Plugin ID	Plugin Name	Plugin Family	CVSS v2.0	Known Exploit?	Publication Date	Count
182741	Oracle Linux 8 : kvm_utils3 (ELSA-2023-12855)	Oracle Linux Local Security Checks	7.8	-	2023/03/06	1
144564	Oracle Linux 8 : ELSA-2020-5620-1: / postgresql:12 (ELSA-2020-56201)	Oracle Linux Local Security Checks	7.6	-	2020/02/13	1
186668	Oracle Linux 8 : edk2 (ELSA-2023-13025)	Oracle Linux Local Security Checks	7.1	-	2022/12/15	1